Módulo 25: Evaluación de vulnerabilidades de terminales

Resumen de ciberseguridad

1. Perfiles de redes y servidores

Perfil de red

- Sirve para tener **información estadística de referencia**: un punto de comparación para el **rendimiento normal** de la red y del dispositivo.

Elementos importantes del perfil de red:

- **Duración de la sesión**
- **Rendimiento total**
- **Puertos utilizados**
- **Espacio de direcciones de activos críticos**

Perfil de servidor

- Se usa para establecer el **funcionamiento aceptado** de los servidores.
- Es una referencia de seguridad para un servidor específico.

Establece:

  - La **red**
  - El **usuario**
  - Los **parámetros de aplicaciones** que se aceptan para ese servidor

Comportamiento de la red y big data

- El comportamiento de la red se puede describir con muchos datos distintos: características del **flujo de paquetes**, particularidades de los mismos paquetes y **telemetría** de múltiples fuentes.
- El **análisis de big data** sirve para detectar anomalías **estadísticas, comportamentales y basadas en reglas**.

Probar la seguridad de la red

Herramienta o servicio	Qué es
Análisis de riesgos	Evaluación del riesgo que representan las vulnerabilidades para una organización específica
Evaluación de vulnerabilidades	Usa software para analizar servidores de Internet y redes internas en busca de distintos tipos de vulnerabilidades
Pruebas de penetración	Usan **ataques simulados autorizados** para probar la solidez de la seguridad de la red

2. Sistema Común de Puntuación de Vulnerabilidades (CVSS)

Qué es

- Es un **marco abierto, independiente y estándar del sector** para ponderar los riesgos de una vulnerabilidad con distintas métricas.
- Da **puntuaciones estandarizadas** de vulnerabilidades, a las que se les debe dar importancia en las organizaciones.
- Es un framework abierto: el significado de cada métrica está disponible para todos.
- Permite **priorizar el riesgo** de forma significativa para cada organización.

Los 3 grupos de métricas

Grupo	Qué hace
Base	Evalúa las **vulnerabilidades de seguridad** de los sistemas de software y hardware
Temporal	Modifica la puntuación base según el **historial de la vulnerabilidad**
Ambiental	Modifica la puntuación base según el **contexto de la organización** específica

Cómo se clasifican las vulnerabilidades

- Vector de ataque
- Complejidad del ataque
- Privilegios necesarios
- Interacción del usuario
- Alcance

Calculadora y puntuaciones

- Hay una **calculadora CVSS** en el sitio web de **FIRST**.
- Produce un número que describe la **gravedad del riesgo** de la vulnerabilidad.
- Las puntuaciones van de **0 a 10**.
- Los rangos tienen valores cualitativos: **cero, bajo, medio, alto o riesgo crítico**.
- En general, hay que atender cualquier vulnerabilidad que supere el valor de **3,9**.
- Mientras **mayor sea la clasificación, mayor la urgencia** de obtener una solución.

Otras fuentes de información de vulnerabilidades

- **CVE:** Vulnerabilidades y Exposiciones Comunes.
- **NVD:** Base Nacional de Datos sobre Vulnerabilidades.
- Las dos están disponibles en línea.

3. Administración segura de dispositivos

Gestión de riesgos

- Implica **seleccionar y especificar controles de seguridad** para una organización.

Hay **4 formas de responder a los riesgos**:

Respuesta	Qué significa
Evasión de riesgos	**Interrumpir** la actividad, el sistema o el servicio vulnerables porque el riesgo es demasiado alto
Reducción del riesgo	Tomar medidas para **mitigar** el riesgo y limitar su impacto
Riesgo compartido	**Externalizar** la responsabilidad del riesgo o usar un **seguro** para cubrir los daños
Retención de riesgos	**Aceptar** el riesgo y no tomar ninguna acción

Administración de vulnerabilidades

- Es una práctica de seguridad para **prevenir de forma proactiva** que se exploten las vulnerabilidades de TI de una organización.

El ciclo de vida tiene **6 pasos**:

Paso	Qué se hace
1	Detectar
2	Priorizar activos
3	Evaluar
4	Informar
5	Remediar
6	Verificar

Administración de activos

- Implica sistemas que **rastrean la ubicación y configuración** de dispositivos y software en la red de toda la empresa.

MDM (Mobile Device Management)

- Permiten al personal de seguridad **configurar, monitorear y actualizar** un conjunto muy diverso de clientes móviles **desde la nube**.

Administración de configuraciones

- Se ocupa del **inventario y control** de las configuraciones de hardware y software de los sistemas.

Administración de parches

- Está relacionada con la administración de vulnerabilidades. Implica todos los aspectos de la aplicación de parches de software: **adquisición, distribución, instalación y verificación**.
- Algunas regulaciones de cumplimiento la **exigen**.

Técnicas:

  - Análisis **basado en agentes**

- Análisis **sin agentes**
- **Supervisión pasiva** de redes

Módulo 26: Administración de riesgos y controles de seguridad

Resumen de ciberseguridad

1. Administración de riesgos

- **Riesgo:** probabilidad de pérdida debido a una amenaza, un acto malicioso o un evento inesperado que daña los sistemas de información o los recursos de la organización.
- **Impacto del riesgo:** el daño que causa un evento que provoca la **pérdida de activos** o la **interrupción de los servicios**.
- **Objetivo de la administración de riesgos:** reducir estas amenazas a un **nivel aceptable** e implementar controles para mantener ese nivel.
- El riesgo puede ser **interno, externo o ambos**.
- Su impacto puede afectar a toda la organización y a otras entidades externas.

Proceso de administración de riesgos

Paso	Qué se hace
1	**Enmarcar** el riesgo
2	**Evaluar** el riesgo
3	**Responder** al riesgo

2. Evaluación de riesgos

Evaluación de amenazas

- Es la **base** de la evaluación de riesgos.
- **Amenaza:** el potencial de que una vulnerabilidad sea identificada y explotada.
- **Vector de amenaza:** la ruta que usa un atacante para afectar el objetivo.
- Las fuentes de amenazas se clasifican en: **adversarios, accidentales, estructurales y ambientales**. Pueden ser internas o externas.
- Las organizaciones examinan sus riesgos operativos con una **evaluación de riesgos** para garantizar que la administración de riesgos cumpla con todos sus objetivos comerciales. Determinan si la amenaza es **baja, aceptable o alta**.

Los 4 objetivos de un análisis de riesgos

- Identificar los **activos** y su valor.
- Identificar **vulnerabilidades y amenazas**.
- **Cuantificar** la probabilidad y el impacto de las amenazas identificadas.
- **Equilibrar** el impacto de la amenaza con el costo de la contramedida.

Tipos de análisis de riesgos

Análisis	Cómo funciona
Cuantitativo	Asigna **números** al análisis de riesgos. Usa fórmulas que requieren:

Análisis	Cómo funciona
	valor del activo, factor de exposición, expectativa de pérdida única, tasa de ocurrencia anual y expectativa de pérdida anual
Cualitativo	Usa **opiniones y escenarios** que trazan la **probabilidad** de una amenaza contra su **impacto**

Matriz de riesgos

- Herramienta que ayuda a **priorizar** los riesgos para decidir a cuáles debe la organización desarrollar una respuesta.
- Los resultados se pueden clasificar y usar como guía para decidir si la organización toma alguna medida.

Mitigación de riesgos

- La buena mitigación busca un **equilibrio** entre el impacto negativo de las contramedidas y controles y el beneficio de reducir el riesgo.

Enfoques posibles:

Enfoque	Qué significa
Aceptación del riesgo y re-evaluación periódica	Aceptar el riesgo y revisarlo cada cierto tiempo
Reducción del riesgo	Implementar **controles**
Eliminación total del riesgo	Modificar el enfoque
Transferencia del riesgo	Pasar el riesgo a un **tercero**

3. Controles de seguridad

- Son **salvaguardas o contramedidas** que una organización implementa para **evitar, detectar, contrarrestar o minimizar** los riesgos de seguridad de sus recursos.

Por naturaleza del control

Control	Qué es
Administrativos	Procedimientos y **políticas** que la organización implementa cuando maneja información confidencial
Técnicos	**Hardware o software** implementado para administrar el riesgo y dar protección
Físicos	Mecanismos como **cercas y cerraduras** para proteger sistemas, instalaciones, personal y recursos

Controles de seguridad funcional

Son **6 tipos**:

Control	Qué hace
Preventivos	**Evitan** que se produzcan actividades no deseadas o no autorizadas y/o aplican **restricciones** a los usuarios autorizados
Disuasivos	Buscan **desalentar** que algo suceda. Los profesionales de ciberseguridad y las empresas los usan para limitar o mitigar una acción o un comportamiento
De detección	Los **controles de detección de acceso** identifican distintos tipos de **actividad no autorizada**
Correctivos	**Contrarrestan** algo indeseable al **restaurar el sistema** a un estado de confidencialidad, integridad y disponibilidad. También pueden restaurar los sistemas a la normalidad luego de una actividad no autorizada
De recuperación	**Restauran recursos, funciones y capacidades** después de la violación de una política de seguridad
Compensatorios	Ofrecen **opciones a otros controles** para reforzar el cumplimiento en respaldo de la política de seguridad

Módulo 27: Análisis forense digital y análisis y respuesta a incidentes

Resumen de ciberseguridad

1. Manejo de evidencia y atribución del ataque

Informática forense digital

- Es la **recuperación e investigación** de la información de dispositivos digitales relacionada con actividades delictivas.
- Los **indicadores de compromiso** son la evidencia de que se produjo un incidente de ciberseguridad. Hay que **conservarlos** para futuros análisis y atribuciones.
- La organización necesita **procesos y procedimientos** bien documentados para el análisis forense digital.
- NIST SP 800-86: Guía para la Integración de Técnicas Forenses en Respuesta a Incidentes. Es un recurso valioso.

Los 4 pasos del proceso forense

Paso	Nombre
1	Recolección
2	Examen
3	Análisis
4	Presentación de informes

- **IETF RFC 3227:** describe un orden para recolectar la evidencia digital según la **volatilidad de los datos**.
- **Cadena de custodia:** implica la **recolección, el manejo y el almacenamiento seguro** de la evidencia.

Atribución de amenazas

- Es la identificación de los **actores responsables** de la amenaza. Debe hacerse con una **investigación sistemática y fundamentada en la evidencia**.
- El equipo de respuesta correlaciona las **TTP** (Tácticas, Técnicas y Procedimientos) del incidente con las de otros ataques conocidos.
- Las fuentes de **inteligencia de amenazas** ayudan a relacionar las TTP con ataques similares.
- En amenazas **internas**, descubrir los dispositivos desde donde se inició el ataque puede llevar directo al actor.
- Otra forma de atribuir: **modelar el comportamiento** del actor de amenaza.
- **MITRE ATT&CK** (Marco de Tácticas Adversariales, Técnicas y Conocimiento Común): permite detectar tácticas, técnicas y procedimientos del atacante como parte de la defensa y la atribución.

2. La Cadena de Eliminación Cibernética (Cyber Kill Chain)

- Tiene **7 pasos**. Ayudan a los analistas a entender las **técnicas, herramientas y procedimientos** de los actores de amenazas.
- Al responder a un incidente, el objetivo es **detectar y detener el ataque lo antes posible** dentro de la cadena.

N.°	Paso	Qué pasa
1	**Reconocimiento**	El actor de amenaza hace una **búsqueda**, reúne inteligencia y selecciona objetivos
2	**Armamentización**	Usa la información del reconocimiento para **desarrollar un arma** contra sistemas o individuos que son blancos específicos
3	**Entrega**	El arma se transmite a los objetivos usando un **vector de entrega**
4	**Explotación**	Una vez entregada el arma, el actor la explota para **obtener el control** del objetivo
5	**Instalación**	El actor establece una **puerta trasera** para seguir accediendo al objetivo. Es importante que el acceso remoto no alerte a los analistas ni a los usuarios
6	**Comando y Control (CnC)**	El actor **establece el control** sobre el objetivo. Usa los canales de CnC para **emitir comandos** al software instalado
7	**Acciones sobre Objetivos**	El agente de amenaza consigue su objetivo original: **robo de datos**, un ataque **DDoS** o usar la red atacada para enviar **correo no deseado** o **minar Bitcoin**

3. El Modelo de Diamante del Análisis de Intrusiones

- Representa un **incidente o evento de seguridad**.
- **Evento:** una actividad de tiempo limitado, restringida a un paso específico, donde el adversario usa la capacidad sobre la infraestructura para atacar una víctima y lograr un resultado específico.

Los 4 componentes principales

- **Adversario**
- **Capacidad**
- **Infraestructura**
- **Víctima**

Metacaracterísticas

- Amplían ligeramente el modelo: **marca de tiempo, fase, resultado, dirección, metodología y recursos**.

Uso por el analista

- Se puede pedir usarlo para **diagramar una serie de eventos de intrusión**.
- Los adversarios **no ejecutan un solo evento**: los eventos se entretejen en una **cadena**, y cada evento debe completarse con éxito antes del siguiente.
- Esa serie de eventos se puede asignar a la **Cadena de Eliminación Cibernética**.

4. Respuesta a incidentes

Qué es

- Son los **métodos, políticas y procedimientos** que usa una organización para responder a un ciberataque.

Objetivos:

  - **Limitar el impacto** del ataque
  - **Evaluar los daños y causas**
  - **Implementar procedimientos de recuperación**

- Hay que crear y mantener **planes detallados** de respuesta y **designar al personal responsable** de ejecutar todos los aspectos del plan.
- Recomendaciones del NIST: SP 800-61 Revisión 2, Guía de Manejo de Incidentes de Seguridad Informática.

CSIRC

- El primer paso es establecer una **capacidad de respuesta ante incidentes de seguridad informática (CSIRC)**.
- NIST recomienda crear políticas y planes, y establecer y mantener un CSIRC.

Partes interesadas del CSIRC:

  - Gerencia
  - Aseguramiento de Información
  - Soporte de TI
  - Departamento Legal
  - Relaciones Públicas y con los Medios
  - Recursos Humanos
  - Planificadores de Continuidad Comercial
  - Seguridad Física y Administración de las Instalaciones

- El **equipo legal** debe consultar las regulaciones gubernamentales para determinar la responsabilidad de informar el incidente.
- NIST recomienda trabajar con **otras organizaciones** para compartir información sobre incidentes.

- Cada organización debe tener una política que detalle **cuánto tiempo se conserva la evidencia** de un incidente.

CMMC (Modelo de Madurez de Ciberseguridad)

- Se creó para evaluar la capacidad de las organizaciones que trabajan para el **Departamento de Defensa de EE. UU. (DoD)** de proteger la cadena de suministro militar de interrupciones o pérdidas por incidentes de ciberseguridad.
- Especifica **17 dominios**, cada uno con un número variable de capacidades.
- La organización se califica por el **nivel de madurez** que alcanzó en cada dominio, y la CMMC la **certifica por nivel**.

Las 4 fases del ciclo de vida de NIST

Fase	Nombre
1	Preparación
2	Detección y Análisis
3	Contención, Erradicación y Recuperación
4	Actividades Posteriores al Incidente

1. Preparación

- Se crea el **CSIRT** y se adquieren e implementan las **herramientas y activos** que el equipo necesita para investigar los incidentes.

2. Detección y análisis

- Los incidentes se detectan con **muchos métodos** y no todos son claros.
- Dos categorías de señales de un incidente: **precursor** e **indicador**.
- Algoritmos complejos y **aprendizaje mecanizado** pueden determinar si un incidente es válido.
- Un método útil es crear **perfiles de la red y del sistema**.
- Cuando el CSIRT cree que hubo un incidente, hace de inmediato un **análisis inicial** para determinar el **alcance** (qué redes, sistemas o aplicaciones se vieron afectados, quién originó el incidente y cómo está ocurriendo).
- Luego se **analiza y prioriza** el incidente.
- Se **notifica** a las personas y partes interesadas internas y externas, para que todos los que necesitan involucrarse desempeñen sus funciones.
- Es fundamental tener **documentación clara y concisa** para preservar la evidencia.

3. Contención, erradicación y recuperación

- **Identificar a los atacantes no es lo más importante**: lo que importa es **contener y erradicar** el ataque y **recuperar** los hosts y servicios.
- Después de la contención, el primer paso de la **erradicación** es identificar todos los hosts que necesitan correcciones.

- Hay que corregir o **parchear** los efectos del incidente y todas las vulnerabilidades que aprovechó el atacante, para que no vuelva a ocurrir.

4. Actividades posteriores al incidente

- La organización debe **informar y revisar la efectividad** del proceso de manejo de incidentes.
- También identifica el **fortalecimiento necesario** para los controles y prácticas de seguridad existentes.

5. Recuperación tras un desastre

Tipos de desastre

Tipo	Característica
Naturales	Difieren según la **ubicación** y, a veces, son **difíciles de predecir**
Causados por el hombre	Involucran a **personas u organizaciones**

DRP (plan de recuperación ante desastres)

- Incluye actividades para **evaluar, recuperar, reparar y restaurar** las instalaciones y los activos dañados.

Medidas	Qué incluyen
Preventivas	Controles que **impiden** que ocurra un desastre
De detección	Controles que **detectan eventos no deseados**
Correctivas	Controles que **restauran el sistema** después de un evento o desastre

Continuidad de los negocios

- Los controles son **mucho más que una copia de respaldo** de los datos y redundancia del hardware.
- Un plan de continuidad comercial empieza con un **análisis de impacto comercial (BIA)**, para identificar procesos comerciales críticos, recursos y relaciones entre sistemas.
- El BIA se centra en las **consecuencias de interrumpir** las funciones comerciales críticas y examina estas consideraciones clave:
  - **RTO**
  - **RPO**
  - **MTTR**
  - **MTBF**
- El **NIST** desarrolló mejores prácticas sobre la continuidad de los negocios.

Capacitación para el plan de recuperación

Método	Qué es
Ejercicio de mesa	Los participantes se sientan con un **facilitador** que da información sobre un incidente de escenario y los procesos que se examinan. **No se invocan procesos reales**: solo se discuten
Prueba funcional	Se prueban **ciertos aspectos** de un plan para ver qué tan bien funcionan (y qué tan preparado está el personal)
Ejercicios operativos completos (simulaciones)	Es el extremo: están diseñados para **interrumpir los servicios** y verificar que todos los aspectos del plan estén implementados y sean suficientes para responder al tipo de incidente simulado